

DOKUMEN ANALISIS RISIKO KEAMANAN INFORMASI

Nama Sistem: QuickFix BE & FE (Aplikasi Manajemen Farmasi & Kasir)
Versi: 1.0
Tanggal Kerja: Juni 2026
Penyusun: Tim Keamanan Informasi / Pengembang Sistem QuickFix

1. Identifikasi Aset Informasi (Asset Identification)

Sebelum menganalisis risiko, aset kritis di dalam sistem QuickFix dikelompokkan sebagai berikut:

ID Aset	Nama Aset	Jenis Aset	Tingkat Kekritisan (H/M/L)	Deskripsi
A-01	Data Pasien & Profil	Data	HIGH	Riwayat alergi, kondisi kronis, tanggal lahir, dan nomor telepon pasien (terikat aturan kerahasiaan medis).
A-02	Resep Dokter	Data / Berkas	HIGH	Berkas resep digital atau unggahan yang divalidasi oleh Apoteker untuk penebusan obat keras.
A-03	Basis Data Inventaris	Data	MEDIUM	Nomor batch obat, tanggal kadaluarsa, jumlah stok, dan master

				data supplier.
A-04	API Endpoint / Token	Software / Akses	HIGH	Jalur komunikasi backend (Django) dan frontend (Nuxt) menggunakan token autentikasi.

2. Identifikasi Ancaman, Kerentanan, dan Penilaian Risiko

Berikut adalah daftar risiko keamanan utama yang ditemukan pada alur kerja teknis QuickFix yang telah kita bangun:

R-01: Bypass Autentikasi / Serangan Brute Force pada Akses Kasir & Apoteker

- **Ancaman:** Pihak eksternal mencoba menebak password akun Kasir atau Apoteker untuk masuk ke sistem manajemen internal.
- **Kerentanan:** Belum adanya pembatasan *rate limiting* atau *account lockout* (penguncian akun) pada API Login Django jika salah password berkali-kali.
-
- **Tindakan Mitigasi (Controls):**
 1. Mengimplementasikan django-axes pada Django backend untuk mengunci IP/Username setelah 5 kali gagal login.
 2. Mewajibkan penggunaan password dengan kombinasi huruf besar, kecil, angka, dan simbol pada PatientSignupSerializer.

R-02: Kebocoran Data (Data Breach) Melalui Ekstraksi File Spreadsheet Impor

- **Ancaman:** File spreadsheet lama yang diunggah berisi data supplier atau harga beli diakses oleh pengguna yang tidak berwenang.
- **Kerentanan:** Fitur unggah file pada ProductActionsView menggunakan parsing multi-part tanpa validasi tipe file yang ketat.
-
- **Tindakan Mitigasi (Controls):**
 1. Membatasi parser Django hanya menerima ekstensi .xlsx atau .csv asli (bukan file

malware yang diubah ekstensinya).

2. Seluruh proses pembacaan data wajib dibungkus dengan `with transaction.atomic()` agar jika terjadi kegagalan atau injeksi karakter aneh, database langsung melakukan *rollback*.

R-03: Manipulasi Stok/Inventaris via Injeksi Request API (PUT/POST Bypass)

- **Ancaman:** Pengguna dengan peran Kasir/Cashier mencoba manipulasi stok batch obat menggunakan aplikasi pihak ketiga seperti Postman, langsung menembak ke endpoint `batch/action`.
- **Kerentanan:** Pengecekan otorisasi berbasis peran (*Role-based access control*) di backend belum seketat middleware di frontend.
-
- **Tindakan Mitigasi (Controls):**
 1. Menambahkan kustom permission class di Django View untuk memastikan endpoint `batch/action` hanya bisa dieksekusi jika `request.user.role` adalah PHARMACIST atau ADMIN.
 2. Mencatat setiap perubahan secara permanen ke dalam tabel `StockMovement` dengan kalkulasi selisih (`tmp_quant`) yang dikunci dari manipulasi manual frontend.

R-04: Pemalsuan QR Code Transaksi Pengambilan Obat

- **Ancaman:** Pasien atau oknum luar membuat QR Code tiruan menggunakan generator gratis di internet untuk mengambil obat keras yang belum dibayar.
- **Kerentanan:** Input pencarian `orderSearchQuery` pada halaman kasir (`scan.vue`) menerima teks mentah tanpa tanda tangan digital kriptografi.
- **Tindakan Mitigasi (Controls):**
 1. Enkripsi teks di dalam QR Code yang dibuat oleh Nuxt (`<Qrcode />`) menggunakan format token berwaktu (misal: JWT atau hash SHA-256 yang berisi ID Order + Timestamp).
 2. Backend Django wajib memverifikasi validitas tanda tangan hash tersebut sebelum merespons dengan data rekam medis pasien di layar kasir.

4. Rencana Aksi Pemulihan & Peninjauan (Review Plan)

Semua tindakan mitigasi dengan status **HIGH** harus diselesaikan dan diuji coba di lingkungan *staging* sebelum aplikasi QuickFix dideploy ke server *production*. Peninjauan ulang dokumen risiko ini wajib dilakukan minimal **6 bulan sekali** atau setiap kali ada penambahan fitur besar (seperti integrasi gerbang pembayaran otomatis / *payment gateway*).